

Valutazione tecnica esecuzioni e readiness NIS2

Data valutazione: February 25, 2026. Aggiornamento stato: February 25, 2026 (post-remediation). Ambito: backend FastAPI, frontend React/Vite, test funzionali legacy, test unit, security/compliance pipeline locale.

Sintesi esecutiva

Le analisi tecniche eseguite mostrano che il prodotto è funzionalmente stabile su molti flussi core e, dopo remediation, il gate tecnico di compliance è verde.

Restano comunque elementi organizzativi/procedurali NIS2 da dimostrare con evidenze operative firmate (drill, training completati, supplier review).

Verdetto operativo: **pronto sul piano tecnico, non ancora attestabile al 100% sul piano organizzativo NIS2** al 25 febbraio 2026.

Analisi effettuate

1. Test applicativi backend/frontend (rerun)

Run di riferimento: `compliance/evidence/test-runs/rerun-2026-02-25-v4/` .

Esiti sintetici:

- Verifiche UAT backend su import utenti e assegnazione business role: PASS.
- Verifiche UAT backend su flusso finale role mining: PASS.
- Verifica logica di merge tra sorgenti dati utenti: PASS.
- Test di integrazione KPI backend: PASS.
- Test unit frontend sulla vista KPI/model quality: PASS.
- Gate tecnico di compliance/security in modalita strict: PASS.

Descrizione:

- I test applicativi principali richiesti nel rerun sono stati riportati in verde.
- Sono stati allineati test legacy al login multi-tenant con dominio manuale.
- I test frontend sono stati adeguati a Vitest/jsdom e allo stato UI attuale.

2. Compliance strict pipeline

Output: `compliance/evidence/test-runs/rerun-2026-02-25-v4/compliance_strict_after_fix.out` . Summary machine-readable: `compliance/evidence/summary.json` .

Risultato: **PASS**.

Dettaglio controlli policy (da `summary.json`):

- `detect_secrets_total` : value `0` , threshold `0` -> pass
- `bandit_medium` : value `0` , threshold `0` -> pass
- `bandit_high` : value `0` , threshold `0` -> pass
- `pip_audit_vulnerabilities` : value `0` , threshold `0` -> pass
- `npm_high` : value `0` , threshold `0` -> pass
- `npm_critical` : value `0` , threshold `0` -> pass
- `semgrep_error` : value `0` , threshold `0` -> pass

Nota tecnica:

- In ambiente locale ci sono limiti rete/trust store per alcuni tool (`pip-audit` , `npm audit` , `semgrep`), ma con i fallback report previsti e dopo remediation il gate finale risulta conforme alla policy impostata.

3. Verifica multi-tenant e compatibilit  legacy

Interventi implementati e verificati:

- Compatibilit  payload su `/api/users` con doppia shape (`items` e `users`).
- Compatibilit  payload su `/api/rolemining/run` con chiavi legacy oltre a stato `async`.
- Allineamento test legacy a login con dominio tenant (`example.internal`).

Esito:

- Flussi legacy principali tornati eseguibili e in gran parte verdi nel rerun.
- Multi-tenant login manuale supportato nei test e nell'app.

Stato rispetto a NIS2

Cosa e coperto positivamente

- Esiste una baseline tecnica di verifica (test + compliance script).
- Esiste evidenza tracciabile di esecuzione con output persistiti.
- Vulnerabilit  critiche/high da dependency audit risultano `0` in questa run.
- Test funzionali principali richiesti nella sessione risultano passati.

Gap residui per attestazione completa

- Mancano evidenze operative firmate per i controlli organizzativi NIS2 (incident drill, training completion, supplier review, continuity drill).
- Le procedure sono state create e versionate, ma non tutte risultano ancora eseguite con verbale allegato.
- L'attestazione finale NIS2 richiede validazione management/compliance oltre al solo esito tecnico del codice.

Giudizio finale

Con le evidenze disponibili al February 25, 2026, il sistema   **tecnicamente allineato** ai gate di sicurezza definiti.

Il livello attuale  : **readiness tecnica raggiunta, readiness organizzativa in completamento.**

Per arrivare a un giudizio di pass serve almeno:

1. Completare e firmare evidenze NIS2 extra-codice (processi e controlli organizzativi/regolatori) in un pacchetto audit unico.
2. Eseguire drill incident reporting (24h/72h/1 mese) con verbale firmato.
3. Completare registro training e supplier review con approvazioni formali.
4. Eseguire e allegare drill BCP/restore con misura RTO/RPO effettiva.

Evidenze principali

Elementi testati (descrittivi)

- Autenticazione multi-tenant con dominio cliente inserito manualmente in login.
- Isolamento logico tenant e compatibilit  con endpoint legacy.
- Import CSV utenti con validazione assegnazione business role e gruppi.
- Flusso role mining end-to-end (avvio processo, output e compatibilit  payload).
- Calcolo KPI e coerenza indicatori backend.
- Rendering e comportamento vista KPI/model quality lato frontend.
- Controlli secret scanning su codice sorgente.
- Analisi SAST backend con focus su vulnerabilit  medium/high.
- Audit dipendenze applicative (backend/frontend) con valutazione severit .
- Scan regole semgrep e verifica error-level findings.
- Generazione SBOM CycloneDX per tracciabilit  supply-chain.
- Valutazione policy finale con soglie a zero su finding bloccanti.
- Predisposizione documentale governance per incident reporting, supply-chain, formazione, continuit  operativa e indice audit trail.